

Transfer Hook Feature Audit Report

Table of Contents

1. Executive Summary

About Loopscale

Audit Summary

Risk Profile

Overall Security Posture

Launch Recommendations

Audit Scope

3

3

3

3

3

4

4

2. Assumptions and Considerations

Trust Assumptions

5

5

3. Severity Definitions

Impact

Likelihood

Severity Classification Matrix

6

6

6

6

4. Findings

L01: Deferred TransferFee activation bypasses mint validation

L02: Token account with withheld_amount > 0 could prevent liquidation or withdrawal of collateral assets

8

8

10

About Us

About Adevar Labs

Audit Methodology

1. Program Context and Architecture Analysis

2. Threat Modeling

3. In-depth Manual Security Review

4. Detailed Fix Review and Validation

Confidentiality Notice

Legal Disclaimer

13

13

13

13

13

14

14

14

14

1. Executive Summary

About Loopscale

Loopscale is an order book-based lending platform on Solana. The system uses direct order book matching instead of pooled liquidity to improve capital efficiency and risk management, featuring isolated markets, fixed-rate terms, and specialized primitives like Vaults and Loops for enhanced user experience.

Audit Summary

This focused security review examined the integration of Token-2022 TransferHook extension support for collateral tokens within the Loopscale lending protocol.

The audit scope was limited to changes introduced in the **feat-transfer-hook** branch, specifically covering:

- Transfer hook integration in token transfer operations
- Token-2022 extension validation logic for TransferFee and TransferHook extensions
- Addition of a **withdraw_all** flag in the **withdraw_collateral** function

Risk Profile

The following table summarizes the distribution of identified vulnerabilities by risk level:

Risk Level	Count	Fixed	Acknowledged
Critical	0	-	-
High	0	-	-
Medium	0	-	-
Low	2	2	0

Number of Enhancement Opportunities: 0

Overall Security Posture

After-fix Review

The two issues have been fixed:

- Before adding a token as collateral to a market, a check ensures that no fees are deferred and can be set in the future.
- The protocol now skips the process of closing a token account if it has a positive withheld amount of fees.

Before-fix Review

The LoopScale team has demonstrated a good understanding of the Token-2022 Transfer Hook extension by correctly implementing the required logic for its integration within the transfer logic.

Transfer Hooks represent a risk as they allow an external program to execute logic before a transfer happens. Because LoopScale positions itself as a permissionless lending platform, it is assumed that market owners will only approve non-malicious tokens.

Our security review identified two low-severity issues that would benefit from being fixed to reduce LoopScale's reliance on market owner due diligence:

- Tokens are checked for their fee value at the current epoch, but are not checked for the newly programmed fees at the time of market integration.
- Some edge cases where token accounts have a positive withheld amount of fees could prevent liquidation or withdrawal of collateral tokens.

Launch Recommendations

After-fix Review

The two issues have been fixed.

Before-fix Review

Strongly Recommended:

- Fix the two identified issues
- Document trust assumptions and market owner responsibilities in protocol documentation

Audit Scope

- **Repository:** <https://github.com/LoopScaleLabs/loopscale-program-library>
- **Files/Modules in Scope:**
- PR: `staging←feat-transfer-hook`
- **Fixes reviewed on commit** `7cd382cdd9b77b47a4ed024313ce26d2100439b7`

2. Assumptions and Considerations

Trust Assumptions

- I. The protocol assumes that market owners who approve tokens with transfer hook extensions trust the token issuer not to maliciously enable hooks after approval.
- II. The protocol assumes that callers will pass remaining accounts in the correct order to avoid causing issues in downstream operations.
- III. The protocol assumes that callers will pass remaining accounts to the hook program with correctly configured account mutability to ensure no unexpected modification of accounts occurs during its execution.

3. Severity Definitions

Each issue identified in this report is assigned a severity level based on two dimensions: **Impact** and **Likelihood**. These dimensions help project our team's understanding of both the potential consequences of a vulnerability and how likely a vulnerability is to be discovered and exploited in the real world.

Impact

Impact reflects the potential consequences of the issue—particularly on **project funds, user funds**, and the **availability or integrity** of the protocol.

- **High Impact:** Successful exploitation could result in a complete loss of user or protocol funds, disruption of core protocol functionality, or permanent loss of control over critical components.
- **Medium Impact:** Exploitation could cause significant disruption or partial loss of funds, but not a total compromise. May impact some users or non-core functionality.
- **Low Impact:** The issue has minor or negligible consequences. It may affect edge cases, expose metadata, or degrade performance slightly without putting funds or core logic at serious risk.

Likelihood

Likelihood reflects how easy a vulnerability is to discover and exploit by an attacker, as well as how economically attractive the exploit is to an attacker.

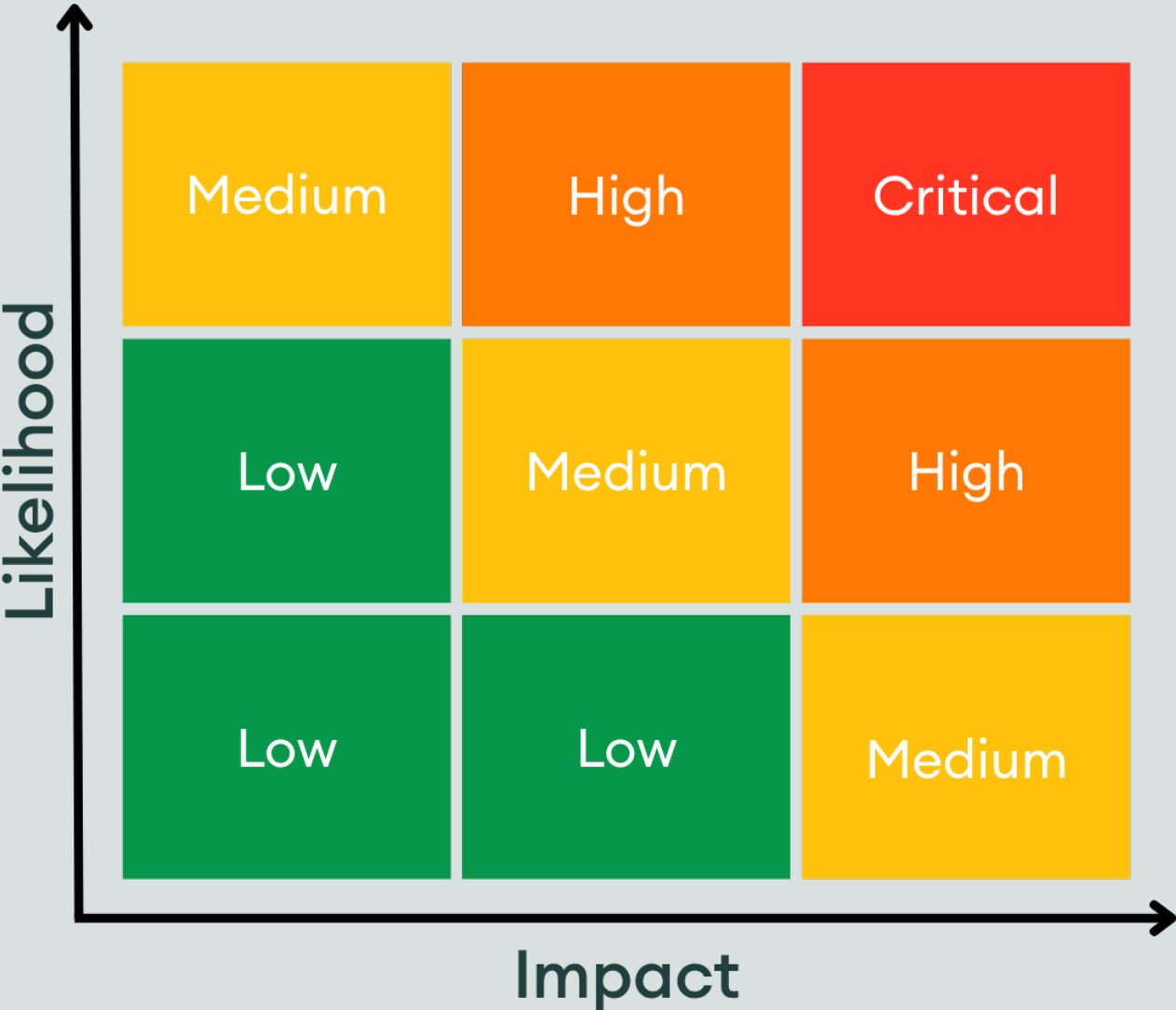
- **High Likelihood:** The vulnerability is trivially exploitable. This means it can be exploited by a wide range of actors without privileged access rights, with minimal capital requirements and low financial risks.
- **Medium Likelihood:** This type of vulnerability can be found and exploited with moderate effort. It might require a significant capital investment, but with manageable financial risk.
- **Low Likelihood:** Exploitation of these vulnerabilities is often technically unfeasible or requires highly specialized conditions. They may require extraordinary effort or a significant financial risk for an attacker, with a high chance of failure and minimal potential return.

Severity Classification Matrix

By combining **Impact** and **Likelihood**, we assign a severity level using the matrix below:

- **Critical:** High impact + high likelihood (e.g. a bug that could allow anyone to drain a substantial amount of protocol funds with minimal effort)
- **High:** High impact with medium likelihood, or medium impact with high likelihood
- **Medium:** Moderate impact and/or discoverability
- **Low:** Minimal impact or unlikely to be exploited

This structured approach helps teams prioritize fixes and mitigate the most dangerous threats first.



Severity Matrix

About Us

About Adevar Labs

Adevar Labs is a boutique blockchain security firm specializing in web3 audits.

Built by a mix of experienced professionals in traditional enterprise and crypto natives who have contributed to some of the most critical projects in blockchain infrastructure.

Our team's background spans companies like Bitdefender, Asymmetric Research, Quantstamp, Chainproof, and Juicebox, and includes experience securing smart contracts, bridges, and L1 and L2 protocols across ecosystems like Solana, Ethereum, Polkadot, Cosmos, and MultiversX.

With over 100 audits completed and a portfolio that includes custom fuzzers, exploit modeling, and runtime testing frameworks, Adevar Labs brings both depth and precision to every engagement.

Our auditors have discovered critical vulnerabilities, built high-impact tooling, and placed in top positions in premier audit competitions including Code4rena and Sherlock.

Team members hold distinctions such as PhDs in software protection, and key roles at Fortune 500 companies, and leadership of flagship conferences like ETH Bucharest.

With team members having publications with over 1,100 academic citations and trusted by projects securing over \$500M in on-chain value, Adevar Labs blends elite technical rigor with real-world security impact.

We also collaborate with some of the best independent security researchers in the web3 space.

Projects may optionally request specific contributors to be part of their audit.

Audit Methodology

Our audit methodology is specialized to provide thorough security assessments of Solana programs. We focus explicitly on rigorous manual analysis, detailed threat modeling, and careful validation of implemented fixes to ensure your programs operate securely and as intended.

1. Program Context and Architecture Analysis

Our auditors begin by deeply examining your Solana program's documentation, intended functionality, and account design. We meticulously map out program interactions, instruction processing flows, and state management logic. Special attention is given to understanding how your program interfaces with critical Solana system programs, such as the SPL Token Program, Stake Program, and System Program. Last but not least we check external integrations with other Solana projects and verify if the inputs and return values are handled properly.

2. Threat Modeling

We conduct targeted threat modeling tailored specifically for Solana's execution environment. We carefully define attacker capabilities and identify potential vulnerabilities that may arise from Solana-specific issues, including but not limited to:

- Unauthorized account data manipulation
- Improper ownership or signer verification

- Misuse of Program-Derived Addresses (PDAs)
- Incorrect use of Cross-Program Invocations (CPI)
- Failure to adequately handle account privileges or account states
- Risks stemming from rent-exemption and account initialization logic

3. In-depth Manual Security Review

Our experienced auditors perform an extensive manual security review of your Rust-based Solana programs. This involves a comprehensive line-by-line inspection of source code, focusing on common Solana vulnerabilities including, but not limited to:

- Missing or insufficient ownership checks
- Inadequate signer checks
- Incorrect handling of CPI calls and invocation privileges
- Arithmetic and integer overflow or underflow errors
- Unsafe deserialization and serialization of account data structures
- Improper token transfers and SPL-token logic issues
- Logic flaws in financial operations or state transitions
- Edge-case handling in instruction input validation
- Potential denial-of-service vectors related to transaction execution and account handling

During this stage, we clearly document any discovered vulnerabilities, including detailed descriptions, precise severity ratings, and recommendations for secure implementation. In situations where it is not clear how the vulnerability might be exploited we may also include a detailed proof-of-concept exploit including code snippets and instructions on how the exploit could be performed.

4. Detailed Fix Review and Validation

After the initial audit and your team's subsequent remediation efforts, we perform a comprehensive fix review to ensure the vulnerabilities identified have been effectively resolved.

We verify each fix individually, confirming that:

- Corrections effectively eliminate the security risks
- Changes do not inadvertently introduce new vulnerabilities or regressions
- The fixes align closely with Solana best practices and secure coding guidelines

Our detailed validation ensures that security improvements are robust, complete, and aligned with best practices specific to the Solana development ecosystem.

Confidentiality Notice

This report, including its content, data, and underlying methodologies, is subject to the confidentiality and feedback provisions in your agreement with Adevar Labs. These materials are not to be disclosed, extracted, copied, or distributed except to the extent expressly authorized by Adevar Labs.

Legal Disclaimer

The review and this report are provided by Adevar Labs on an as-is, where-is, and as-available basis. To the fullest extent permitted by law, Adevar Labs disclaims all warranties, expressed or implied, in connection with this report, its content, and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement.

You agree that access to and/or use of the report and other results of the review, including any associated services, products, protocols, platforms, content, and materials, will be at your sole risk.

FOR AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE. This report is based on the scope of materials and documentation provided for a limited review at the time provided.

You acknowledge that blockchain technology remains under development and is subject to unknown risks and flaws. Adevar Labs does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party, or any open-source or third-party software, code, libraries, materials, or information accessible through the report. As with the purchase or use of a product or service in any environment, you should use your best judgment and exercise caution where appropriate.